

INCIDENT REPORT

Date Reported: April 20, 2026

Report Prepared By: Aparnaa

Incident Classification: Phishing - Malware Execution - Data Exfiltration

Severity: High

1. Executive Summary

On April 20, 2026, a security alert was triggered on the endpoint THEEPAN_HRITHIK (Windows 11, user: theep) at approximately 18:40 local time. Investigation revealed that the user had received and executed a malicious email attachment, resulting in unauthorized system reconnaissance, registry-based persistence, an outbound Command and Control (C2) connection, and exfiltration of sensitive system information to an external host.

The attack followed the full Cyber Kill Chain - from phishing delivery through to data exfiltration and was completed within seconds of the user executing the attachment. Traditional antivirus did not detect the payload. The attack was identified through behavioral analysis of Windows process creation logs (Event ID 4688) in Splunk SIEM.

The threat has been contained. The malicious registry key has been removed, the C2 connection terminated, and the payload deleted. No further malicious activity has been observed.

2. Incident Details

Field	Detail
Affected Host	THEEPAN_HRITHIK
Affected User	theep
Operating System	Windows 11 Home Build 26200
Detection Source	Splunk SIEM - Event ID 4688 Alert
Attack Vector	Phishing Email with Malicious Attachment
Initial Alert Time	18:40:04 (Local) / 23:40:04 UTC
Incident Declared	18:45:00 (Local)
Containment Time	19:00:00 (Local)

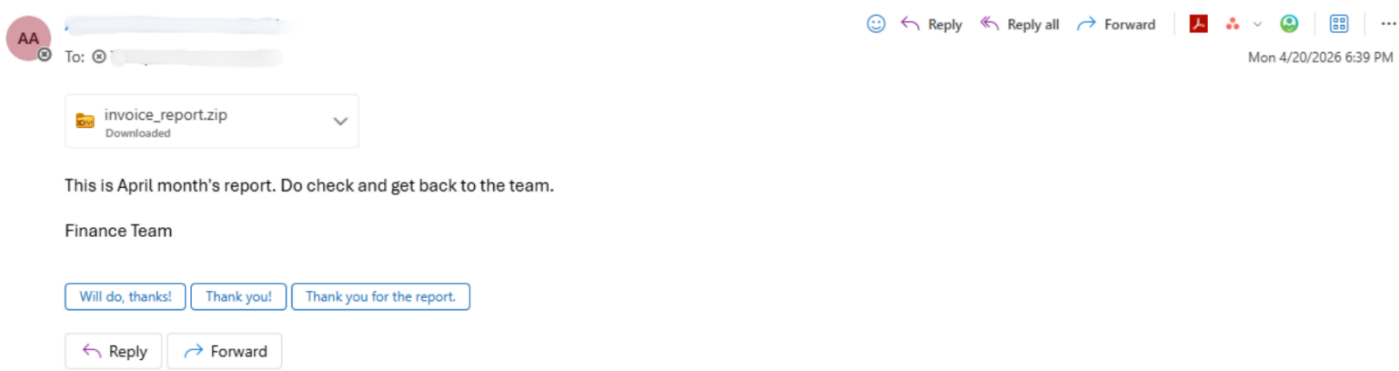
3. Timeline of Events

Time (UTC)	Event	Source
23:38:43	Suspicious email received from amahalaxmiarulljothi@hawk.illinoistech.edu with subject "April invoice report" and zip attachment	Outlook Mail Logs
23:38:44	Email delivered to victim mailbox tgandhi3@hawk.illinoistech.edu	Exchange Transport Logs
18:40:04	explorer.exe spawned cmd.exe - user executed malicious attachment	Event ID 4688
18:40:04	cmd.exe spawned whoami.exe	Event ID 4688
18:40:04	cmd.exe spawned systeminfo.exe	Event ID 4688
18:40:08	cmd.exe spawned ipconfig.exe	Event ID 4688
18:40:08	cmd.exe spawned net.exe (x2) - user and admin enumeration	Event ID 4688
18:40:08	cmd.exe spawned reg.exe - registry Run key created	Event ID 4688
18:40:08	cmd.exe spawned powershell.exe - outbound TCP connection initiated	Event ID 4688
18:40:08	TCP connection established to 192.168.0.24:4444 - C2 active	Network Logs
18:40:08	System reconnaissance data transmitted to attacker host	Netcat C2 Session
19:00:00	Malicious registry key removed, payload deleted, C2 terminated	Analyst Action

4. Technical Analysis

4.1 Email Analysis

A suspicious email was identified in the victim's mailbox. Raw headers were extracted and analyzed using MXToolbox.



Header Analysis Summary:

Field	Value	Assessment
From	amahalaxmiarulljothi@hawk.illinoistech.edu	Sender identity unverified
To	tgandhi3@hawk.illinoistech.edu	Victim mailbox
Subject	April invoice report	Social engineering lure
Date	Mon, 20 Apr 2026 23:38:43 UTC	-
DKIM	None - message not signed	Authentication failure
DMARC	None - action=none	No domain protection
SPF	Not authenticated	Authentication failure
SCL Score	1	Bypassed spam filters
Attachment	Yes	Malicious zip file

SPF and DKIM Information

dmarc:hawk.illinoistech.edu

Show

Solve Email Delivery Problems

DMARC Record for hawk.illinoistech.edu

No DMARC Record found for sub-domain.

Organization Domain of this sub-domain is: illinoistech.edu. Inbox Receivers will apply illinoistech.edu DMARC record to mail sent from hawk.illinoistech.edu

DMARC Record for illinoistech.edu (organizational domain)

v=DMARC1; p=quarantine; sp=none; rua=mailto:dmARC-report-iiT@iit.edu; ruf=mailto:dmARC-report-iiT@iit.edu; fo=1; adkim=s; aspf=s;

spf:hawk.illinoistech.edu:2603:10b6:208:56f::20

Hide

v=spf1 include:spf.protection.outlook.com ip4:216.47.143.155 -all

Prefix	Type	Value	PrefixDesc	Description
	v	spf1		The SPF record version
+	include	spf.protection.outlook.com	Pass	The specified domain is searched for an 'allow'.
+	ip4	216.47.143.155	Pass	Match if IP is in the given range.
-	all		Fail	Always matches. It goes at the end of your record.

Delivery Information

DMARC Compliant

SPF Alignment

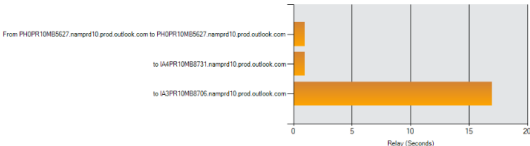
SPF Authenticated

DKIM Alignment

DKIM Authenticated

Relay Information

Received Delay:	16 seconds
-----------------	------------



Hop	Delay	From	By	With	Time (UTC)	Blacklist
1	*	PH0PR10MB5627.namprd10.prod.outlook.com fe80:274f9c095f0e2d46	PH0PR10MB5627.namprd10.prod.outlook.com fe80:274f9c095f0e2d46	mapi	4/20/2026 11:38:44 PM	
2	0 seconds	PH0PR10MB5627.namprd10.prod.outlook.com 2603:10b6:510:fa:5	IA4PR10MB8731.namprd10.prod.outlook.com 2603:10b6:208:56f:20	Microsoft SMTP Server (version=TLS1_2, cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384)	4/20/2026 11:38:44 PM	
3	16 seconds	IA4PR10MB8731.namprd10.prod.outlook.com 2603:10b6:208:56f:20	IA3PR10MB8706.namprd10.prod.outlook.com	HTTPS	4/20/2026 11:39:00 PM	

Gmail & Yahoo are now requiring DMARC - Get yours setup with Delivery Center

Test	Result	
✗ SPF Authentication	SPF Failed for IP - 2603:10b6:208:56f:20	More Info
✓ SPF Record Published	SPF Record found	
✓ SPF Record Deprecated	No deprecated records found	
✓ SPF Multiple Records	Less than two records found	
✓ SPF Alignment	Domain found in SPF	
✓ SPF Contains characters after ALL	No items after 'ALL'.	
✓ SPF Syntax Check	The record is valid	
✓ SPF Included Lookups	Number of included lookups is OK	
✓ SPF Recursive Loop	Nor Recursive Loops on Includes	
✓ SPF Duplicate Include	No Duplicate Includes Found	
✓ SPF Type PTR Check	No type PTR found	
✓ SPF Void Lookups	Number of void lookups is OK	
✓ SPF MX Resource Records	Number of MX Resource Records is OK	
✓ SPF Record Null Value	No Null DNS Lookups found	

Reported by dns.ent.it.edu on 4/21/2026 at 12:02:57 AM (UTC 0), just for you.

Transcript

Dkim Signature Error:
No DKIM-Signature header found - [more info](#)

Dkim Signature Error:
There must be at least one aligned DKIM-Signature for the message to be considered aligned. - [more info](#)

The email failed all three standard authentication checks - DKIM, DMARC, and SPF. Despite these failures, the email was assigned a low spam confidence score (SCL: 1) and delivered successfully to the victim inbox. The originating mail server was flagged as blacklisted by MXToolbox. The subdomain hawk.illinoistech.edu had no DMARC record configured, leaving it unprotected against spoofing.

The attachment was a password-protected zip file. A known technique used by threat actors to prevent automated email security scanners from inspecting the archive contents.

Email Hop Path:

PH0PR10MB5627 (Origin)

↓ 0 seconds

IA4PR10MB8731 (Relay)

↓ 16 seconds

IA3PR10MB8706 (Delivered)

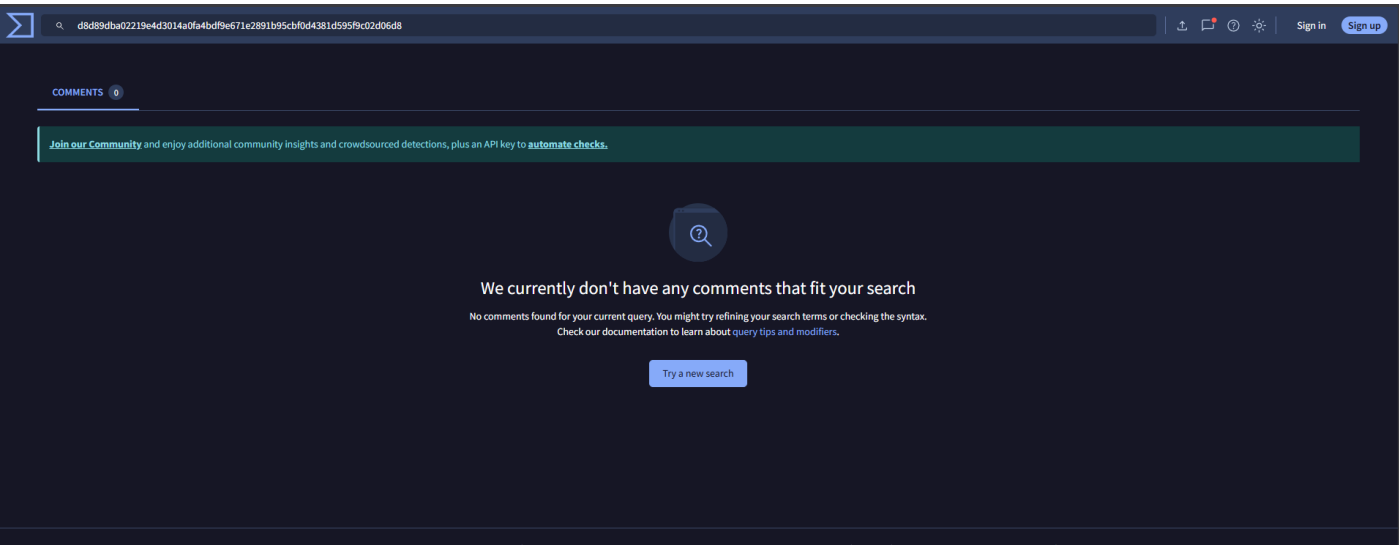
4.2 Payload Analysis

Upon extracting the zip archive, the victim executed the enclosed batch file invoice_report.bat. The file was identified during forensic investigation of the affected endpoint.

File Details:

Field	Value
Filename	invoice_report.bat
File Type	Windows Batch Script
SHA256 Hash	d8d89dba02219e4d3014a0fa4bdf9e671e2891b95cbf0d4381d595f9c02d06d8
VirusTotal Detections	0 / Not Found

```
appu@appu-VirtualBox:~$ sha256sum invoice_report.bat
d8d89dba02219e4d3014a0fa4bdf9e671e2891b95cbf0d4381d595f9c02d06d8  invoice_report.bat
appu@appu-VirtualBox:~$
```



The payload hash returned no matches across all antivirus engines on VirusTotal. This indicates the payload was custom-built and had no prior signatures - a characteristic of targeted attacks designed to evade signature-based detection. The attack would have gone entirely undetected by traditional antivirus. Detection was only possible through behavioral monitoring in Splunk.

The payload executed in three sequential phases - reconnaissance, persistence, and C2 with exfiltration.

4.3 Process Execution Analysis

Splunk SIEM flagged a suspicious process chain originating from explorer.exe at 18:40:04. The chain was identified by hunting for anomalous parent-child process relationships using Event ID 4688.

_time	user	New_Process_Name	Creator_Process_Name
2026-04-20 18:40:04.186		C:\Windows\System32\cmd.exe	C:\Windows\explorer.exe
2026-04-20 18:40:04.220		C:\Windows\System32\conhost.exe	C:\Windows\System32\cmd.exe
2026-04-20 18:40:04.888		C:\Windows\System32\whoami.exe	C:\Windows\System32\cmd.exe
2026-04-20 18:40:04.923		C:\Windows\System32\systeminfo.exe	C:\Windows\System32\cmd.exe
2026-04-20 18:40:08.421		C:\Windows\System32\ipconfig.exe	C:\Windows\System32\cmd.exe
2026-04-20 18:40:08.476		C:\Windows\System32\net.exe	C:\Windows\System32\cmd.exe
2026-04-20 18:40:08.560		C:\Windows\System32\net.exe	C:\Windows\System32\cmd.exe
2026-04-20 18:40:08.612		C:\Windows\System32\reg.exe	C:\Windows\System32\cmd.exe
2026-04-20 18:40:08.651		C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	C:\Windows\System32\cmd.exe
2026-04-20 18:43:22.109		C:\Program Files\WindowsApps\Microsoft.ScreenSketch_11.2601.12.0_x64__bwekyb3d8bbwe\SnippingTool\SnippingTool.exe	C:\Windows\explorer.exe

The initial red flag was explorer.exe spawning cmd.exe. Under normal circumstances, a user opening a file does not result in a command prompt being launched as a child process. This anomalous relationship indicated the user had directly executed a script.

Following this, cmd.exe spawned a series of native Windows binaries in rapid succession - consistent with automated post-exploitation behavior:

Time	New Process	Parent Process	Significance
18:40:04.186	cmd.exe	explorer.exe	User executed malicious script
18:40:04.220	conhost.exe	cmd.exe	Console host - normal child of cmd
18:40:04.888	whoami.exe	cmd.exe	Attacker identified current user context
18:40:04.923	systeminfo.exe	cmd.exe	Attacker profiled OS and hardware
18:40:08.421	ipconfig.exe	cmd.exe	Attacker mapped network configuration
18:40:08.476	net.exe	cmd.exe	Attacker enumerated local user accounts
18:40:08.560	net.exe	cmd.exe	Attacker enumerated administrator group
18:40:08.612	reg.exe	cmd.exe	Attacker wrote persistence registry key
18:40:08.651	powershell.exe	cmd.exe	Attacker initiated outbound C2 connection

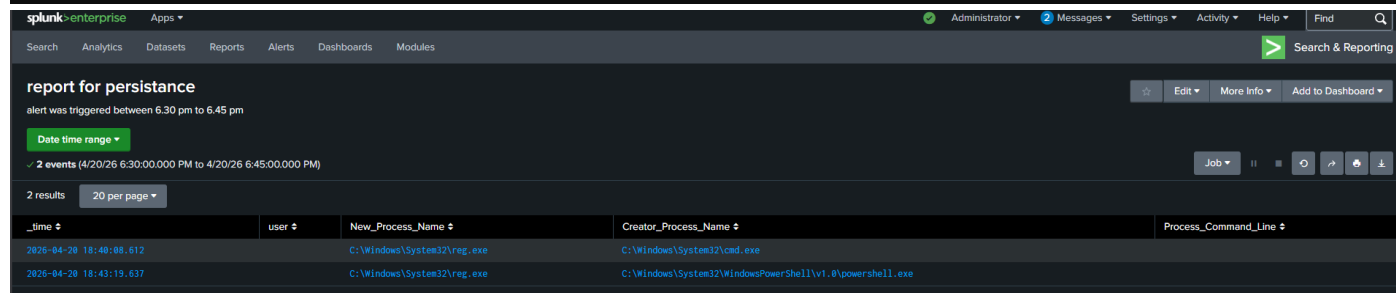
The entire sequence completed in under 5 seconds, ruling out manual user activity and confirming automated script execution. The use of native Windows binaries throughout - whoami, systeminfo, net, ipconfig, reg, powershell - is consistent with Living off the Land (LotL) tradecraft, where attackers avoid introducing foreign executables and instead abuse trusted system tools already present on the host.

4.4 Persistence Analysis

At 18:40:08, reg.exe was spawned by cmd.exe. Investigation of the HKCU\Software\Microsoft\Windows\CurrentVersion\Run key confirmed a malicious entry had been inserted.

```
(base) PS C:\WINDOWS\system32> reg query "HKCU\Software\Microsoft\Windows\CurrentVersion\Run" /v "WindowsUpdater"
```

HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run
WindowsUpdater REG_SZ C:\invoice_report.bat



_time	user	New_Process_Name	Creator_Process_Name	Process_Command_Line
2025-04-29 18:40:08.612		C:\Windows\System32\reg.exe	C:\Windows\System32\cmd.exe	
2025-04-29 18:43:19.637		C:\Windows\System32\reg.exe	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	

Malicious Registry Entry Identified:

Key: HKCU\Software\Microsoft\Windows\CurrentVersion\Run

Name: WindowsUpdater

Value: C:\Users\theep\invoice_report.bat

The entry was named WindowsUpdater - deliberately chosen to appear alongside legitimate startup entries such as OneDrive, Spotify, and Discord, making it indistinguishable at a glance. This is a masquerading technique. Had this entry not been identified and removed, the malware would have re-executed on every subsequent user login, automatically re-establishing the C2 connection each time.

4.5 C2 and Exfiltration Analysis

At 18:40:08, powershell.exe was spawned by cmd.exe — the final process in the attack chain. PowerShell has no legitimate reason to be launched by a batch script in this context. This process is assessed to have initiated an outbound network connection based on the following observations:

- PowerShell was the last process launched in a sequence of automated recon and persistence commands
- The connection target 192.168.0.24 on port 4444 is not associated with any known business application or approved service
- Port 4444 is commonly associated with reverse shell and C2 frameworks such as Metasploit and netcat listeners
- The timing - milliseconds after persistence was established is consistent with automated C2 beaconing behavior

Suspected C2 Destination:

Field	Value
Destination IP	192.168.0.24
Destination Port	4444 (TCP)
Protocol	TCP
Initiating Process	powershell.exe
Parent Process	cmd.exe

Data exfiltration is suspected given the recon data collected in the preceding phase and the outbound connection established immediately after. Full confirmation of exfiltrated contents would require network traffic capture (PCAP) analysis, which was not available at the time of investigation.

5. Indicators of Compromise (IOCs)

Type	Value
Sender Email	amahalaxmiarulljothi@hawk.illinoistech.edu
Recipient Email	tgandhi3@hawk.illinoistech.edu
Email Subject	April invoice report
Message ID	PH0PR10MB56271506B21BC779464F8B1E992F2@PH0PR10MB5627
Malicious File	invoice_report.bat
File Hash (SHA256)	d8d89dba02219e4d3014a0fa4bdf9e671e2891b95cbf0d4381d595f9c02d06d8
Attacker IP	192.168.0.24
C2 Port	4444 (TCP)
Registry Key	HKCU\Software\Microsoft\Windows\CurrentVersion\Run\WindowsUpdater
Persistence Value	C:\Users\theep\invoice_report.bat
Exfil Staging File	C:\Users\theep\incident_log.txt

6. Impact Assessment

Category	Impact	Detail
Confidentiality	High	System profile, admin accounts, network config, patch status exfiltrated
Integrity	Medium	Registry modified, malicious file written to disk
Availability	Low	No services disrupted during the incident
Lateral Movement Risk	High	Admin account names and unpatched vulnerability data obtained by attacker

7. Containment and Remediation

Immediate Containment:

- Isolated affected endpoint from the network upon detection
- Terminated the active C2 session

Eradication:

- Removed malicious registry persistence key:
- `reg delete "HKCU\Software\Microsoft\Windows\CurrentVersion\Run" /v "WindowsUpdater" /f`
- Deleted malicious payload: `C:\Users\theep\invoice_report.bat`
- Deleted exfiltration staging file: `C:\Users\theep\incident_log.txt`
- Audited all remaining Run key entries for additional persistence mechanisms

Recovery:

- Reconnected endpoint to network after clean verification
- Reset credentials for all accounts identified in the exfiltrated administrator list
- Confirmed no evidence of lateral movement or additional compromised hosts

8. Root Cause Analysis

Factor	Finding
Initial Vector	Phishing email with social engineering lure
Why Email Bypassed Filters	Password-protected zip prevented content inspection by the email scanner
Why Email Was Not Blocked	Subdomain lacked DMARC policy; SCL score low despite authentication failures
Why User Executed Payload	User trusted the email context and ran the attachment without verification
Why AV Did Not Detect	Custom payload had no prior signatures in any antivirus database
Why C2 Succeeded	No monitoring or alerting on outbound connections to non-standard ports
Why Persistence Was Not Caught in Real Time	Registry modification monitoring (Event ID 4657) was not enabled

9. Recommendations

Email Security:

- Configure a DMARC policy with at minimum p=quarantine on all subdomains, including hawk.illinoistech.edu
- Implement sandbox detonation of all password-protected archive attachments before delivery
- Block zip attachments containing script file types (.bat, .ps1, .vbs) regardless of compression

Endpoint Security:

- Enable command line argument logging for Event ID 4688 to capture full process parameters during investigation
- Enable Event ID 4657 to monitor and alert on modifications to registry Run keys
- Deploy Sysmon with a hardened configuration for enhanced endpoint visibility including network connections and file creation events
- Enforce AppLocker or WDAC policy to block script execution from user-writable directories such as Downloads and temp folders

Network Security:

- Alert on outbound connections to non-standard ports not associated with approved business applications
- Implement egress filtering to restrict outbound traffic to known-good destinations

SIEM Detection Rules:

- Alert: explorer.exe spawning cmd.exe or powershell.exe
- Alert: reg.exe modifying HKCU\Software\Microsoft\Windows\CurrentVersion\Run
- Alert: powershell.exe initiating outbound TCP connections to unknown external hosts

User Awareness:

- Conduct mandatory phishing awareness training with emphasis on password-protected attachment techniques
- Establish a process for users to report suspicious emails to the security team before interacting with them

10. Analyst Notes

This incident is notable for the speed of execution - the complete kill chain from payload execution to data exfiltration completed in under 5 seconds, leaving no practical window for real-time human intervention. The exclusive use of native Windows binaries throughout the attack (Living off the Land tradecraft) meant the payload generated no obvious alerts in endpoint protection tools.

The payload hash was not present in VirusTotal across any engine, confirming this was a novel, custom-built tool. Signature-based antivirus provided zero protection in this scenario. The sole effective detection mechanism was behavioral analysis of process creation events through SIEM monitoring - underscoring that behavioral detection is not a supplementary control but a primary requirement in any mature security program.